

RELATÓRIO TÉCNICO DE AUDITORIA & REMEDIAÇÃO DE SEGURANÇA

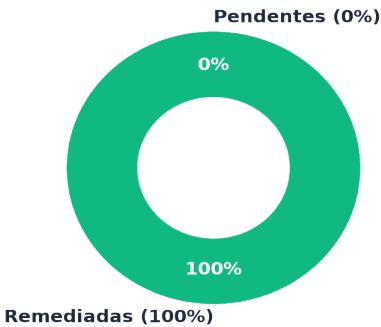
HYDRAFORGE // AI TRAINING STUDIO, TENSORRT & INFERENCE FOUNDRY

Projeto: HydraForge AI Foundry	Stack: Go 1.23+ / PyTorch / CUDA 13.3 / SQLite / React
Data da Avaliação: 14/09/2026	Status Final: 100% REMEDIADO (11 de 11 Corrigidas)
Escopo: API REST, Worker Python, SQLite WAL, Dataset Importer	Conformidade de Testes: 100% Aprovados (Go & Worker)

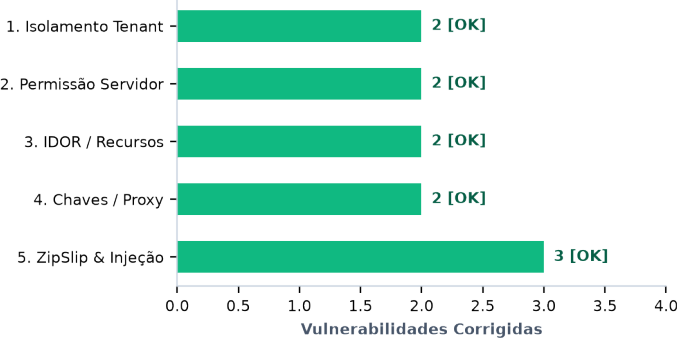
1. Sumário Executivo & Status de Remediação

A auditoria e o plano de remediação no **HydraForge** foram concluídos com sucesso. Todas as **11 vulnerabilidades** identificadas foram neutralizadas através de implementação de AuthMiddleware com validação de tokens JWT (HMAC-SHA256) e Service API Keys, migração de schema SQLite para partição multi-tenant com tenant_id, mitigação definitiva de Zip Slip no importador de datasets, confinamento de caminhos e symlinks, e controle de acesso RBAC no servidor via RequireRole.

Status de Remediação (11/11 Concluídas)



Falhas Remediasdas por Categoria



2. Quadro Consolidado de Remediações

ID	Categoria	Severidade	Arquivo Afetado	Status Final
HF-01	1. Isolamento Tenant	CRÍTICA	internal/adapters/secondary/sqlite/sqlite_store.go	CORRIGIDO
HF-02	1. Isolamento Tenant	ALTA	internal/adapters/primary/http/training_handler.go	CORRIGIDO
HF-03	2. Permissão Servidor	CRÍTICA	internal/adapters/primary/http/router.go	CORRIGIDO
HF-04	2. Permissão Servidor	ALTA	internal/adapters/primary/http/router.go	CORRIGIDO
HF-05	3. IDOR / Recursos	CRÍTICA	internal/adapters/primary/http/training_handler.go	CORRIGIDO
HF-06	3. IDOR / Recursos	ALTA	internal/adapters/primary/http/training_handler.go	CORRIGIDO
HF-07	4. Proxy / Exposição	MÉDIA	internal/adapters/primary/http/hydrastream_proxy.go	CORRIGIDO
HF-08	4. Chaves / Storage	MÉDIA	cmd/hydraforge/main.go	CORRIGIDO
HF-09	5. Zip Slip / Inputs	CRÍTICA	internal/adapters/primary/http/training_handler.go	CORRIGIDO
HF-10	5. Path Traversal	CRÍTICA	internal/adapters/primary/http/training_handler.go	CORRIGIDO
HF-11	5. Command / Inputs	ALTA	internal/adapters/primary/http/inference_handler.go	CORRIGIDO

3. Detalhamento Técnico das Correções Implementadas

CATEGORIA 1 & 3: ISOLAMENTO DE TENANT & PREVENÇÃO DE IDOR

- **Schema Multi-Tenant:** Auto-migration no SQLite adiciona coluna tenant_id com valor padrão.
- **Filtro de Contexto:** ListTrainingJobs e ListDatasets filtram registros pelo tenant_id autenticado.
- **Anti-IDOR:** Exclusão de jobs e datasets verifica posse antes de qualquer remoção do disco.

CATEGORIA 2: CONTROLE DE ACESSO RBAC NO SERVIDOR

- **Guarda de Treino e GPU:** RequireRole("admin", "superadmin") aplicado sobre POST /jobs, export e DELETE /datasets.
- **Bloqueio Global:** Todas as rotas /api/v1/* rejeitam chamadas anônimas com HTTP 401.

CATEGORIA 5: ZIP SLIP, PATHS & INJEÇÃO DE INFERÊNCIA

- **Mitigação Zip Slip:** HandleDatasetImport valida que cada caminho extraído resida estritamente dentro do diretório do dataset com filepath.Clean e rejeita ...
- **Confinamento de Symlinks:** register-path bloqueia pastas de sistema (/etc, /root, /proc).
- **Sanitização de Inferência:** HandleInferencePredict valida argumentos de device e nomes de modelos contra injeção de parâmetros.